

Guidance on ICT Risks in the Use of AI at Financial Entities

Table of contents

I. Introduction	4
1. Definition of an AI system	6
2. Subject matter of the guidance	6
3. Structure of the guidance	8
II. ICT risk management and AI	9
1. ICT risks resulting from the use of AI	9
2. Governance and organisation	9
3. ICT risk management framework under DORA	11
III. Deploying AI: development and testing	12
1. Software development	12
2. Testing AI	14
IV. Operation and retirement of AI	16
1. Processes for operating and deinstalling AI systems	16
2. Specific aspects relating to cloud computing in AI operations	18
V. Cyber- and data security	21
1. Cybersecurity	21
2. Data security	22
3. Reporting major ICT-related incidents	24
VI. Conclusions and outlook	24

I. Introduction

This guidance document serves as non-mandatory advice. It is designed to help financial entities (in particular CRR institutions and Solvency II insurance undertakings) to implement the relevant regulatory requirements under the Digital Operational Resilience Act (DORA)¹ when using artificial intelligence (AI).²

In particular, it addresses ICT risk management and ICT third-party risk management, including the Delegated Regulation on ICT risk management³ (RTS RMF) and the Delegated Regulation on subcontracting of ICT services supporting critical or important functions (RTS Subcontracting)⁴.

This guidance is therefore aimed in particular at those entities supervised by BaFin that are required to comply with the ICT risk management requirements set out in Articles 5 to 15 of DORA. The requirements for the simplified ICT risk management framework (Article 16 of DORA) must be considered separately and are not the subject of the present analysis.

Among other things, the guidance is based on discussions with financial entities and does not constitute a binding interpretation of DORA by BaFin.

Financial entities are deploying AI along their entire value chain. They are doing so for a variety of reasons: a key driver for the use of state-of-the-art AI technology is the desire to achieve greater efficiency and optimised processes; likewise, complex mathematical models enable risks to be assessed more accurately. To illustrate the range of applications for AI at credit institutions and insurance undertakings, it is useful to examine examples from the value chains of these entities.

Credit institutions are using AI in sales to predict customer migration. In lending operations, AI applications can help staff review annual financial statements. In fund management, AI is being used to summarise large volumes of analyst reports on investment instruments.

Insurance undertakings are using interactive AI assistants (chatbots) in sales and customer communication to inform employees or customers about product features. Product pricing can be tailored more precisely to the insured risks by means of complex models and, potentially, using real-time data (dynamic pricing or telematics). In underwriting, AI applications can support risk assessment. Automated input management allows a large number of incoming documents to be routed efficiently. In claims administration, insurers are using AI applications to support loss adjusters in claims adjustment, for example in the automatic payment of small claims. Furthermore, AI applications are being used to detect fraud in claims processing. Currently, applications dominate in areas where the greatest efficiency gains can be achieved, i.e. in particular in customer communication, claims administration and claims processing.

¹ Regulation (EU) 2022/2554 on digital operational resilience in the financial sector

² "Financial entities" means entities defined in Article 2(2) of Regulation (EU) 2022/2554 (DORA) in conjunction with Article 2(1(a) to (t) of DORA.

³ Delegated Regulation (EU) 2024/1774

⁴ Delegated Regulation (EU) 2025/532

In compliance functions, AI is being used to monitor regulatory developments. Corporate communications can use AI to automatically create social media posts. AI is also being used in risk models to more accurately determine capital requirements.

The widespread use of AI assistants is also evident. These are mostly large language models that process and generate unstructured data, such as text and images. Such assistant systems can be used across a wide range of applications, for example to create presentations, source code or videos.

1. Definition of an AI system

This guidance addresses the ICT risks associated with the use of AI systems.

The term “AI system” is legally defined in Article 3(1) of the EU AI Act⁵. This states that an AI system is “a machine-based system that is designed to operate with varying levels of autonomy and that may exhibit adaptiveness after deployment, and that, for explicit or implicit objectives, infers, from the input it receives, how to generate outputs such as predictions, content, recommendations, or decisions that can influence physical or virtual environments”.

“Machine-based” refers to the fact that AI systems are developed with the help of machines and run on machines. “Machines” consist of hardware and software components that enable AI systems to function. The hardware components refer to the physical elements of the machine, such as processing units, memory, network devices and input/output interfaces. Among other things, the software components include computer code, operating systems and applications (see Commission Guidelines of 29 July 2025, C(2025) 5053 final, margin no. 11⁶).

“AI systems” are thus a subset of the broader category of “network and information systems” as defined in Article 3(2) of the Digital Operational Resilience Act (DORA). The use of such machine-based systems and the hardware and software they contain gives rise to ICT risks. This guidance exclusively addresses these ICT risks and is based on the requirements of DORA and the RTS RMF and RTS Subcontracting. The term “machine-based system”, as defined by DORA, is therefore understood to refer to a combination of ICT assets (hardware and software) and infrastructure in which a complex mathematical model is implemented (see also Figure 1). The model itself is understood to be an ICT asset (software).

The term “AI system” used in this guidance should therefore be understood as a combination of ICT assets and ICT infrastructure (see also Figure 1). This guidance does not address the terms “autonomy” and “adaptiveness” contained in the definition of the AI Act, or the mathematical modelling methodology, including the data used, its development or validation.

AI systems – as with ICT systems in general – serve business processes. The nature and scope of an AI system depend on the individual case and must correspond in particular to the business purpose, the risk situation and the relevant context.

2. Subject matter of the guidance

Specific ICT risks are not related to the location of AI systems in a financial entity’s value chain. Rather, they arise from the integration of the AI system into the entities’ ICT landscape. For this reason, the guidance does not address ICT risks along the value chain, but rather along the “AI lifecycle”.

⁵ Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence

⁶ Commission Guidelines on the definition of an artificial intelligence system established by Regulation (EU) 2024/1689 (AI Act)

The security and resilience of an AI system should be ensured throughout this cycle, from data acquisition and model development down to ongoing operation and retirement. In addition to specific safeguards for ICT assets, it is crucial for AI systems to be included within the existing ICT risk management framework.

This guidance deals exclusively with ICT risks and their treatment under DORA and supplementary regulatory technical standards.

Important principles in DORA are the risk-based approach and the proportionality principle (Article 4 of DORA), which must be observed in the implementation of the requirements. This means that in particular those AI applications that are integrated into critical or important functions require more extensive security and control measures than, for example, AI-based self-service assistants that are completely under human supervision and are not involved in decision-making processes.

This guidance document, which is intended to provide non-mandatory advice, does not define any supervisory expectations. As in DORA, the risk-based approach and the principle of proportionality must always be observed.

3. Structure of the guidance

The observations on the security of AI systems are structured as follows:

First, key aspects relevant to ICT risk management (Chapter II) that apply across the entire lifecycle (see Figure 1) are described.

This is followed by discussions of the requirements for AI system development and testing (Chapter III), as well as for operation and retirement (Chapter IV). This includes the principal technical requirements for protecting the AI system. These chapters also consider data flow and ICT assets that are vulnerable to manipulation, data extraction and attacks (see data flow and attack vectors in Figure 1).

The subsequent chapter presents a discussion of generally applicable requirements for cyber- and data security in AI systems (Chapter V). Cyber- and data security aspects play a special role in this context, as they apply across all elements of the AI lifecycle. A final assessment summarises the most important information (Chapter VI).

This guidance document is intended to be a living document that can be adapted to reflect technological progress and new regulatory developments.

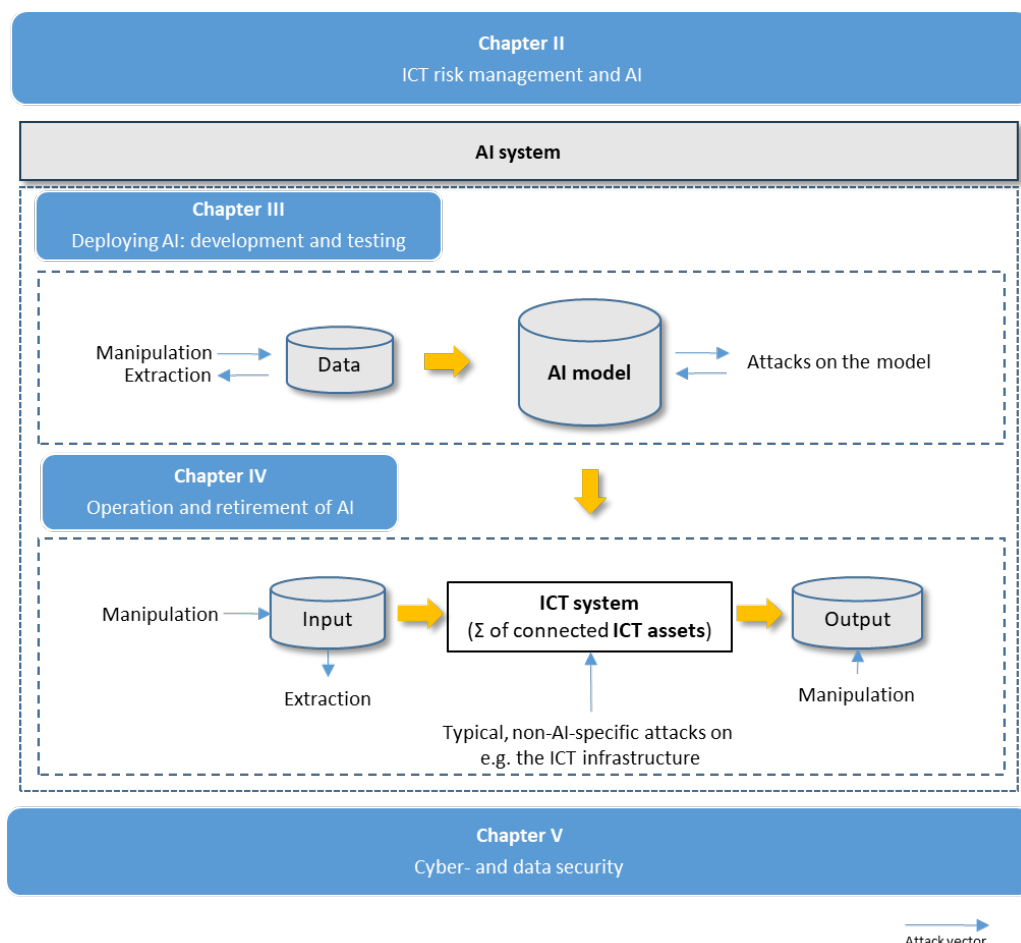


Figure 1: Subject matter and structure of the guidance

II. ICT risk management and AI

1. ICT risks resulting from the use of AI

The implementation and operation of AI applications can involve considerable risks. From a regulatory perspective, the ICT risks inherent in AI systems demand particular attention. AI systems are assessed in the same way as general ICT systems in terms of their risk profile, complexity and the functions they support, such as processing sensitive data or supporting critical or important functions.

Many AI systems cannot be operated without the use of cloud services. This is why *ICT third-party risk* is also very important. The strategic issue of dependence on (a small number of) providers is not the only factor to consider here.

Furthermore, ensuring *data quality and integrity* can represent a major challenge. Manipulated or corrupted data can significantly impair model performance and security. Equally, the uncontrolled reuse or unsafe disposal of AI applications can jeopardise sensitive model or company data.

Cybersecurity is also becoming increasingly important due to the use of complex AI systems. For example, vulnerabilities such as backdoors can be introduced into the model undetected during training. Furthermore, the insecure deployment of software (for example through open source libraries) can lead to attackers stealing or manipulating models. Likewise, adversarial attacks or unauthorised access during model use can lead to wrong decisions being taken by entities.

It is the responsibility of ICT risk management to manage these and other ICT risks. The following sections provide further details on selected DORA requirements for AI systems.

2. Governance and organisation

Risk management begins at the strategic level with the implementation of a suitable governance and organisational structure. Financial entities often develop an AI strategy aligned with their overall strategy, risk strategy and, where applicable, ICT and DOR strategy, and have it approved by their management body. The AI strategy can be a stand-alone strategy, but it can also be integrated into an overarching strategy. Defining an AI strategy becomes particularly significant when AI applications support critical or important functions.

AI strategy. Developing a clear technology roadmap can form the basis of the AI strategy so that the ICT resources, capacities and investments necessary for AI deployment can be defined. AI applications can be seamlessly integrated into existing ICT systems and processes. Continuous innovation management helps to identify and evaluate new technologies and trends in the field of AI.

Throughout a process, it would be helpful to cover and document all steps relevant to the use of AI: from strategy, through development, down to retirement. It is important for the

supervised entity to first review all processes relevant to the use of AI to determine whether they are designed for artificial intelligence and whether there is awareness of how to handle information assets before an AI system is implemented.

The development of AI skills is another important aspect. Training and continuing education ensure that employees have the necessary skills and knowledge to interact with AI systems. They thus ensure that **employees acquire the knowledge appropriate to their area of responsibility in the user departments (Article 13(6) of DORA)**. Encouraging talent and building teams of experts in the field of AI are just as important as internal knowledge transfer through documentation and training events. Where AI systems are used, interdisciplinary collaboration is also becoming increasingly important, for example between the IT department and the user departments.

Governance/organisation. With its governance and organisational requirements, DORA is establishing a cornerstone for achieving high digital resilience in financial entities. Setting up an internal governance and control framework plays a key role here. This is intended to ensure effective and prudent management of ICT risks.

The prominent role of the management body is another key building block. In addition to overall responsibility for setting and approving the digital operational resilience strategy and allocating adequate budgetary resources for the ICT risk management framework, this body has ultimate responsibility for managing the ICT risks of the financial entity (Article 5(2)(a) of DORA).

Furthermore, the members of the management body must acquire and maintain sufficient knowledge and skills, including through specialised training, to understand and assess ICT risks and their impact on the financial entity's operations (Article 5(4) of DORA). It is also necessary for responsibilities to be defined within the organisation and depending on the specific function exercised, e.g. for the use of AI-generated results in decision-making processes.

With regard to general requirements, it is helpful to formulate appropriate guidelines that are consistent with the supervised entity's (DOR) strategy and its information security policies and guidelines.

Among other things, specific arrangements for ITC third-party service providers and their services should ideally take into account a risk assessment, information from the service provider, and the entity's own risk reduction measures. The general requirements should be tailored to the specific use case. In addition, the entity should review whether additional AI-specific measures are necessary. In particular, many financial entities adopt risk-based requirements for the use of AI systems, depending on the criticality of the data used and the location of storage and processing.

When AI systems are deployed, it is common for governance frameworks to require the involvement of the ICT risk management function, control functions and internal audit functions. The involvement of these functions depends on the criticality of the AI system, while maintaining independence and avoiding conflicts of interest.

3. ICT risk management framework under DORA

The *ICT risk management framework* lies at the heart of ICT risk management for AI systems (Article 6 of DORA). This framework serves to effectively manage the ICT risks faced by financial entities.

Article 6(1) of DORA

ICT risk management framework

Financial entities shall have a sound, comprehensive and well-documented ICT risk management framework as part of their overall risk management system, which enables them to address ICT risk quickly, efficiently and comprehensively and to ensure a high level of digital operational resilience.

In Chapter II, DORA sets out harmonised, uniform requirements for ICT risk management across the financial services sectors. In addition to the governance and organisational requirements already outlined above, this also includes the ICT risk management framework. This is intended to ensure that financial entities achieve an appropriate degree of digital operational resilience. In other words, they should become sufficiently resilient and adaptable to be able to maintain their digital operational processes both during and after an ICT-related incident.

As part of overall risk management, the ICT risk management framework includes the following requirements, among others:

- identification under Article 8 of DORA,
- protection and prevention under Article 9 of DORA,
- detection under Article 10 of DORA,
- response and recovery under Article 11 of DORA,
- learning and evolving under Article 13 of DORA and
- communication under Article 14 of DORA.

As in the case of other ICT assets, AI systems must also be integrated into the ICT risk management framework. This includes identifying vulnerabilities (for example in model training, data pipelines or inference) and assessing quantitative and qualitative risk criteria (Article 8 of DORA). Additionally, measures for addressing identified risks, such as the use of adversarial training methods or the monitoring of model drift, must be documented and reviewed regularly (Article 9 of DORA).

The ICT risk management framework must be reviewed at least once a year (Article 6(5) sentences 1 and 2 of DORA). In addition, financial entities must be able to submit a report on the review of their ICT risk management framework in a searchable electronic format at the request of the competent authority. Among other things, the report must document the current risk status, the measures taken and any weaknesses identified (Article 27 of the RTS RMF). If required, this report can also be supplemented with specific information on AI systems.

III. Deploying AI: development and testing

1. Software development

If financial entities develop AI systems themselves, they usually do so within the standard processes designed for this purpose. This gives them full control over the software and mathematical models. Software development not only requires sufficient specialised knowledge and skills, but also places demands on the design of the development process. In this case, too, the DORA requirements apply to AI systems.

Knowledge and skills. The development of AI systems places high demands on the skills of employees and management. Employees tasked with AI-related responsibilities face the challenge of acquiring appropriate and relevant skills and knowledge about how the AI systems work, the risks associated with them, and the technical and organisational characteristics of cloud and on-premise operations.

In particular, the ability to develop software with the support of AI assistants can enable users outside the ICT function to create even complex applications themselves. The requirements for **knowledge and skills referred to above (Article 16(9) of the RTS RMF) also apply here**, including with regard to testing.

Management, and in particular the members of the management body, can also contribute to assessing and managing the risks associated with software development by having a sufficiently deep understanding of AI systems (Article 5(4) and Article 13(6) of DORA).

The extent of the knowledge required will depend on the tasks involved: the more technical the tasks, the more specific the knowledge will have to be. Due to the rapid pace of technological progress in the field of artificial intelligence, it is necessary to regularly train employees and continuously monitor the pace of development. Typically, training measures are defined for employees involved in developing, operating and maintaining AI systems (Article 13(6) of DORA).

Development process. When introducing and further developing AI systems, it helps to establish robust project management that covers all phases (planning, development, testing, rollout and operation). This includes clear objectives, the establishment of governance structures, **detailed project risk assessments and testing procedures** (see below) (Article 15 of the RTS RMF).

Standard software engineering practices such as unit testing, integration testing and source code reviews have proven their worth in the development and validation of AI systems. Regular, ideally automated, testing and validation procedures are suitable for ensuring accuracy and reliability. A secure and separate environment for the experimental development and testing of AI systems is essential.

Comprehensive documentation in the form of technical specifications can contribute to the reproducibility and transparency of AI system development. In addition to the technical ICT

specifications, it is also useful to describe the algorithms, data and parameters used (Article 16 of the RTS RMF).

AI systems are procured, developed and maintained in accordance with security and functionality requirements, in the same way as ICT systems. This typically involves defining technical specifications that also include security requirements, such as protection against manipulation (Article 16 of the RTS RMF).

Any changes to AI systems (whether to the software or hardware) are generally subject to strict change management, which includes an independent review, documented testing and specifying fall-back procedures. In addition, procedures, protocols, and tools must be established to manage emergency changes that provide adequate safeguards. The goal is to mitigate the risk of unintended security breaches or manipulation (Article 17 of the RTS RMF).

Version control systems are useful for tracking changes to AI models and applications. They make it possible to trace errors and reproduce results. Systematic archiving of all model versions and parameters ensures reusability and reproducibility (Article 17(1) to (2) of the RTS RMF). DORA does not distinguish between applications developed within the ICT function and those developed outside the ICT function (often referred to as “end-user computing” (EUC)) (Article 16(9) of the RTS RMF). If it becomes necessary to develop AI systems outside the ICT function, this must also be carried out in accordance with the processes described above.

Several approaches have proven helpful in practice in developing and modifying AI systems to meet DORA requirements. For the training process, these measures include:

- ensuring that training and testing data comes from trustworthy sources;
- ensuring that (open-source) libraries and software packages used for training do not contain any known vulnerabilities;
- documenting and versioning the entire training process to guarantee transparency and reproducibility;
- using security analyses to identify hidden manipulations in the model or training data.

Use of open source libraries. Internally developed and purchased software for AI systems can also use open source libraries. In extreme cases, this can even include the use of an open source model that is implemented, trained and operated on the hardware of a financial entity itself. The aspects of the development process described above have also proven to be relevant here. There is also a risk with open source software that malicious code could be introduced via these libraries. Additionally, there is a risk that the libraries will no longer be maintained after a few years. In this case, the AI system may contain identified but unresolved vulnerabilities and no longer correspond to the latest state of the art.

Generating source code using AI assistants. Software developers are increasingly using AI assistants to create applications more efficiently. In principle, the same rules apply to all types of source code creation, whether by humans or machines. However, one challenge is to review machine-generated source code to determine the extent to which AI-based functions unknown to the user are being invoked. Among other things, this can be identified through

static code analysis (Article 16(3) of the RTS RMF). Deeper source code analyses and reviews of quality, reproducibility and understandability can provide additional assurance.

Appropriate documentation of the source code has proven to be advisable for downstream testing.

2. Testing AI

An important step in the deployment of AI systems is hardware and software testing. In this case, too, the general requirements of DORA apply to AI systems.

The RTS RMF describes in detail the measures to be taken for testing ICT systems (Article 16(2) of the RTS RMF). For example, security testing is required as part of the source code review for internet-exposed systems and applications (Article 16(3) of the RTS RMF).

Scope of testing. Financial entities are required to develop, document and implement tests. The level of testing must be commensurate to the criticality of the business procedures and ICT assets concerned. The testing must be designed to verify that new ICT systems – and hence also AI systems – are appropriate for their intended purpose. This also includes the quality of software developed internally (Article 16(2) of the RTS RMF).

Source code. The RTS RMF contains specific requirements for working with source code from application development. For example, the source code must be checked for anomalies using static and dynamic testing procedures before it is deployed in the production environment (Article 16(3) of the RTS RMF).

In particular when integrating open source libraries, entities are encouraged to ensure that the functions used do not contain any AI-based functionalities whose risks are unknown to the financial entity or cannot be mitigated (Article 16(3) of the RTS RMF).

The test also requires proprietary software (compiled source code) and, where feasible, source code provided by ICT third-party service providers or coming from open source projects to be analysed and tested before being deployed in the production environment (Article 16(8) of the RTS RMF).

One challenge in testing is to identify whether applications integrate external AI models, for example via APIs (application programming interfaces). These can transform software originally planned as a non-AI application into an AI system.

Generative AI. The use of generative AI poses particular challenges for testing. The large language models (LLMs) typically used have a complex internal structure (known as a “transformer” structure), with a large number of peripheral models that are connected to the actual model. The transformer structure is based on deep neural networks with several billion parameters (known as “weights”). LLMs are trained by the provider on the basis of large data sets (e.g. Wikipedia). Users can retrain (“fine-tune”) the model, but this requires a large amount of computing power.

Since generative AI is suitable for general purposes, testing is more difficult than with internally developed software that has been designed for a specific application. General

testing procedures for LLMs can take the internal structure of the models into account (e.g. by considering the probabilities for generating a specific token stream for a given input prompt) or can be designed to be agnostic. In the latter case, the model answers test questions, for example, and the **quality of the answers is assessed by a human or another model**. Another challenge for testing arises from **unannounced model changes** where an AI model obtained from third parties is used.

Several approaches have proven suitable for meeting the protection objectives of DORA when developing and modifying AI systems. The following measures may be appropriate, depending on criticality:

- simulating attacks on AI systems (adversarial testing, e.g. data poisoning, evasion attacks);
- conducting adversarial penetration testing (e.g. in coordination with the cloud provider) to simulate AI-specific attacks;
- stress-testing the performance of AI systems, e.g. with significantly modified data distributions or in overload scenarios;
- In the case of AI systems not developed internally, it may also be appropriate to involve the manufacturer of the system in the tests and, if necessary, to obtain appropriate evidence of their performance.

IV. Operation and retirement of AI

1. Processes for operating and deinstalling AI systems

Appropriate processes must be defined for the operation of ICT systems. Ideally, these processes take into account the specifics of AI systems, e.g. whether they involve connecting an LLM from a cloud service provider or software developed internally in the entity's own data centre.

When defining operating processes, it is necessary to cover the entire AI system lifecycle. This includes requirements for the development, installation, operation and deinstallation of AI systems, as well as the documentation of all operating activities, such as log files from model inference processes (Article 8 of the RTS RMF).

Identification and documentation. DORA requires a policy as well as procedures for managing information and ICT assets (Article 8(4) of DORA in conjunction with Articles 4 and 5 of the RTS RMF). Information and ICT assets (including components of AI systems) must be identified, classified, documented and continuously monitored. This also applies, for example, to **training data sets, model implementations, software libraries, hardware, and internally and externally developed software**. Clear criteria regarding the criticality of these assets provide additional support for classification.

Documenting information and ICT assets makes it possible to clearly trace where e.g. training data comes from, where it is stored within the lifecycle, who owns it and who is responsible for it (Article 4(2)(b) of the RTS RMF).

Capacity and performance. Entities are encouraged to regularly review AI systems in terms of their resource requirements and performance in order to avoid capacity bottlenecks and safeguard their stable availability. **Automated monitoring procedures must be used to ensure the efficiency and scalability of the AI infrastructure** (Article 9 of the RTS RMF).

Deinstallation. Entities are encouraged to include specifications for deinstalling AI systems in their policies and procedures, to irretrievably remove AI models after deletion, and to govern the **deactivation of obsolete model versions in order to prevent misuse** (Article 8(2)(a)(i) of the RTS RMF).

Attacks. During operation, AI systems must be protected against common cyber threats such as adversarial attacks, model poisoning and inference attacks. **Appropriate technical security measures are required to counter these threats (Article 9(3) of DORA)**. This is explored in greater detail in the case study on the use of AI assistants.

Role-based access rights for AI models and training data are also an effective tool. These must be regularly verified and documented (Article 21 of the RTS RMF).

Article 10 of DORA

Detection

Financial entities shall have in place mechanisms to promptly detect anomalous activities (including ICT network performance issues and ICT-related incidents) and to identify potential material single points of failure.

Detection. Continuous monitoring of AI systems has proven useful for the early detection of anomalies (Article 10 of DORA). This makes it possible to identify deviations from expected behaviour at an early stage.

Regular, automated vulnerability scanning and assessments are part of early detection. This includes examining software libraries, frameworks and the source code of AI software developed in house or obtained from third parties. Setting clear deadlines and escalation processes for implementing patches is also

helpful (Article 10 of the RTS RMF).

Furthermore, entities are encouraged to ensure comprehensive, risk-based logging of AI decisions, model versions and training data (to the extent permitted by data protection law), depending on the criticality and area of application of the relevant AI systems. For AI systems that support critical or important functions, it is advantageous to define thresholds and indicators for misconduct. It is also recommended to test them regularly for effectiveness (Article 10(1) second subparagraph in conjunction with paragraph (2) of DORA).

Article 11 of DORA

Response and recovery

Effective and appropriate ICT business continuity management limits the impact of ICT-related incidents and ensures the continuation of critical or important functions at the financial entity.

Response and recovery, backup. The failure of AI systems, for example due to ICT-related incidents, can have serious consequences for financial entities.

Depending on their criticality, it makes sense to include AI systems accordingly in ICT business continuity management and, in particular, in the above-mentioned plans. Recovery times and points (Article 12(6) of DORA) must also be taken into account.

To ensure their functionality in an emergency, these plans must be tested and documented regularly (at least annually) (Article 11(6)(a) of DORA and Article 25 of the RTS RMF).

Financial entities must also include ICT third-party service providers that they have obtained AI systems from in their ICT business continuity management (Article 11(4) and Article 28 of DORA).

In addition, restoration and recovery procedures and methods, as well as policies and procedures for backing up AI systems and their data (e.g. regular backups of model artefacts and data sets), should be considered (Article 12(1) to (3) and (7) of DORA). Their scope is largely determined by the criticality of the information and the confidentiality of the data. The security of network and information systems and the protection objectives of the data may

not be compromised. Where AI systems provided by third-party providers (e.g. through API access) are used, this role is usually assumed by the provider. Specifics for AI systems provided by third parties can be found in the next section.

It is also advisable to maintain adequate redundant capacities for AI systems, consistent with the relevant business needs (Article 12(4) of DORA).

Lessons learned from ICT-related incidents and from challenges in activating ICT business continuity plans and ICT response and recovery plans must be systematically assessed and integrated into the refinement of systems, models and processes (Article 13(3) of DORA). This also applies to the ICT risk assessment process for AI systems.

2. Specific aspects relating to cloud computing in AI operations

In the supervisory statement on outsourcing to cloud service providers, published on 1 February 2024⁷, BaFin and the Deutsche Bundesbank presented their joint assessment of this outsourcing. Some of these aspects can also be applied to AI systems when AI is operated in the cloud. The following section highlights overlaps and selected AI characteristics.

Risk assessment and due diligence (Cloud supervisory statement, Chapter III.2). Before entering into a contract with a cloud service provider, financial entities should conduct a comprehensive risk assessment (Article 28(4)(c) of DORA) that considers technical, operational and regulatory aspects. This assessment should also consider changes to the AI system (e.g. retraining or adaptation of the model structure), even if all changes to the model are made by the service provider. Before entering into a contract with a cloud provider, entities are encouraged to perform a risk inventory of the AI application (materiality, data sensitivity, technical requirements). It is also expedient to comply with the required due diligence obligations (Article 28(4)(d) of DORA) and to ensure the suitability of the cloud service provider. This also extends to potential conflicts of interest (Article 28(4)(e) of DORA). When using cloud services, the financial entity should also consider the risks of unauthorised data leakage, including to the cloud service provider.

Cyber- and information security (Cloud supervisory statement, Chapter IV.2). In the context of cybersecurity, potential risks from attack vectors (including adversarial attacks and data poisoning) in externally hosted training or inference environments should be identified. In addition, ICT third-party service providers (e.g. cloud service providers, external data science services) should be evaluated in terms of security standards, certifications and data protection before contracts are entered into. These ICT third-party service providers must comply with information security standards that are, as a minimum, appropriate (Article 28(5) of DORA). If critical or important functions are to be supported, financial entities must consider the most up-to-date and highest quality information security standards when selecting them (Article 28(5) of DORA).

⁷ This refers to the German version.

Article 28 of DORA

General principles for ICT third-party risk management

Financial entities shall manage ICT third-party risk as an integral component of ICT risk within their ICT risk management framework.

Contracts and subcontracting (Cloud supervisory statement, Chapter III.5). There must be clear arrangements governing whether and under what conditions the cloud service provider may use further subcontractors (subcontracting, sub-delegation) (Article 30(2)(a) of DORA). In the case of AI-specific subcontracting that supports critical or important functions (e.g. specialised ML libraries, GPU farms, AI security services), the entity must at all times maintain an overview of which parties are involved in data processing (Article 3(6) of the ITS Register of Information), where (location/region) this takes place (Article 30(2)(b) of DORA) and how potentially long or complex chains of subcontracting may impact the process (Article 29(2) of DORA).

For AI applications that support critical or important functions, financial entities must enter into clear service level agreements (SLAs) and security agreements with ICT third parties (Article 30(3)(a) and (c) of DORA). The SLAs should clearly and unambiguously define how performance, availability and security requirements will be met. Since AI systems are particularly sensitive to latency and computing power, these SLAs typically also cover these aspects.

Furthermore, audit and control rights should also apply without exception to subcontracts that support critical or important functions (Article 3(1)(d) and Article 4(1)(j) of the RTS Subcontracting) in order to obtain insight into relevant AI logs, training environments and security measures, for example in the event of an audit. In addition, a review should be conducted to establish whether the provider meets regulatory expectations (e.g. Cloud supervisory statement, SLA requirements, subcontractor transparency) (Article 3(1)(c) and (j) of the RTS Subcontracting).

Exit strategy and portability (Cloud supervisory statement, Chapter IV.4). An important aspect of using the cloud is the termination or migration of cloud outsourcing. As part of an exit strategy for AI applications that support critical or important functions, financial entities should ensure that they can maintain operations or migrate promptly in the event of problems, such as non-compliance with supervisory requirements by the cloud service provider or a change of provider (Article 28(7) and (8) of DORA). Entities are encouraged to ensure that models, training data and configuration scripts can be exported seamlessly to ensure portability to another environment.

Financial entities should be aware that proprietary cloud functions (e.g. specialised AI offerings) can significantly increase the costs, duration and technical expertise required for a change (known as "vendor lock-in"). These should therefore be explicitly considered in the risk assessment. Before a contract is entered into, the formats in which training data, models and metadata can be exported (e.g. Docker images, storage snapshots) must be clarified to ensure that the entity can remain operational in the event of failure or change of cloud

service provider (Article 28(8) and Article 30(3)(f) of DORA). This data should be saved regularly to a storage location that is independent of this cloud service provider.

Tests of scenarios for emergencies (e.g. cloud failure, data corruption, problems with a subcontractor) must be performed regularly for AI applications that support critical or important functions, see Article 28(8) third subparagraph of DORA.

Audit and inspection rights (Article 30(3)(e) of DORA; Cloud supervisory statement, Chapter III.5.3). For significant outsourcing or contractual arrangements for the use of ICT services to support critical or important functions, the competent authority (in particular BaFin) and the outsourcing entity must be granted the right to audit the cloud service provider.

V. Cyber- and data security

AI systems can serve as gateways for cyberattacks and data manipulation. Cyber- and data security aspects should therefore be considered for all elements of the AI lifecycle. This is the only way to ensure that AI can be operated securely and resiliently, particularly within the framework of ICT risk management in accordance with DORA. The following guidance contains aspects which, in contrast to development and operation, apply across the entire lifecycle and incorporate AI-specific features.

1. Cybersecurity

AI systems are attractive targets for cyberattacks, especially because they process sensitive data and may be included in decision-making processes (see attack vectors in Figure 1). Comprehensive security measures and regular security checks are therefore of the utmost importance.

DORA requires financial entities to **develop ICT security policies** (Article 9(2) of DORA). AI systems should also be adequately considered in these policies. In particular, the policies should include measures for network security, data transmission (Article 2(1) of the RTS RMF) and protection against data misuse. For AI systems, this means that, in addition to securing model access, **secure data sharing between training data, model components and end users should also be ensured.**

System security. Robust data and system security (Article 11 of the RMF RTS) is essential for combating cyberattacks. Proactive defence mechanisms based on threat analyses and up-to-date security information are necessary.

Certain measures have proven to be effective in this regard:

- using firewalls, **IDS/IPS systems and zero-trust models** to prevent attacks on the AI infrastructure;
- using **data loss prevention (DLP)** mechanisms to prevent unauthorised access to AI data;
- specialised resilience tests for AI systems to validate their resistance to AI-specific risks, such as **adversarial attacks and data set manipulation.**

Network security. In addition, network security must be guaranteed at all times. The networks in which ICT and AI systems are operated must be segmented based on their criticality and protected against unauthorised access. Special measures must be implemented (e.g. firewall rules, encryption of network communication) to ensure the integrity and confidentiality of data traffic (Article 9 of DORA and Article 13 of the RTS RMF).

Financial entities establish network security policies and procedures that address specific requirements for AI systems. Ideally, the criticality and importance of AI systems should also be appropriately reflected in the separation and segmentation of ICT systems and networks (Article 13(a) of the RTS RMF). As AI systems can process confidential information, entities are encouraged to apply risk-based physical and/or technical protection for network access.

A number of security measures have become established for network hardening:

- using web proxies to examine, monitor and secure network traffic, considering all unencrypted and encrypted communication;
- using web application firewalls and API gateways to filter attacks at application level;
- protecting AI systems from DDoS attacks from the internet;
- establishing VPN and remote desktop access and automatically terminating remote sessions.

Authorisation management. Strict access controls and authorisation management systems are necessary for preventing unauthorised access to sensitive data. Consequently, authentication and authorisation procedures must be implemented to restrict access to sensitive data. Comprehensive logging of all data access attempts and modifications is necessary for identifying and tracking suspicious activity. **Role-based access control (RBAC)** systems can ensure that users only have access to the data they need for their work (Article 9(4)(c) of DORA and Article 21(a) of the RTS RMF).

Monitoring and logging. Entities are encouraged to log all relevant events and activities in AI systems. The purpose of logging is to ensure reproducibility and detect anomalous activities, and it is typically protected against manipulation (Article 12 of the RTS RMF).

Article 24.25 of DORA

Digital operational resilience testing

Financial entities shall implement a sound and comprehensive digital operational resilience testing programme as an integral part of the ICT risk management framework.

ICT change management. **For emergency changes to AI systems, special approval and assessment processes can be defined that enable changes to be made at short notice (Article 17(1)(f) and (g) of the RTS RMF).**

Resilience testing. DORA also requires financial entities to conduct regular resilience testing (Articles 24, 25 of DORA). Advanced testing based on TLPT is not considered here

(Articles 26 to 27 of DORA).

Numerous measures have proven effective to ensure AI system cybersecurity. These include:

- continuous real-time monitoring of AI systems for anomalous behaviour (e.g. unexpected decision patterns);
- establishing protective mechanisms against adversarial inputs, e.g. using filter mechanisms;
- logging the relevant output of the AI system and API calls for subsequent analysis;
- regularly updating the AI system to counter new threats;
- having a contingency plan for handling security incidents in the AI system.

2. Data security

Financial entities process personal data. It is important that they protect this data, including when deploying AI systems.

Data classification, transfer and encryption. Classification is the most important basis for secure processing and storage of an entity's data. Requirements for confidentiality, integrity and availability must be considered. This classification determines how and where data can be processed and stored (Article 5(2)(b) of the RTS RMF). Such a classification is an additional valuable means of protecting data when AI systems are operated in the cloud. DORA requires financial entities to classify all their data accordingly (Article 11(2)(k) of the RTS RMF).

AI systems are encrypted in compliance with the defined requirements, i.e. following appropriate data classification and ICT risk assessment. This covers data that is stored, transmitted or, where necessary, used. If encryption cannot be carried out during processing, as a minimum other measures, such as processing the data in a separate and protected environment, are necessary (Article 6(2) of the RTS RMF). **Secure management of cryptographic keys, for example to protect communication channels between AI system components, is recommended.** DORA explicitly requires the use of appropriate encryption methods, cryptographic controls and key management (Articles 6 and 7 of the RTS RMF).

Transferring data between AI system components, as well as between AI systems and external services, is also typically secured in order to protect against e.g. data leaks. Procedures for monitoring and assessing compliance with these requirements must be established (Article 14 of the RTS RMF).

Practices have emerged that can be adapted to individual entities:

- encryption and signing of models to prevent unauthorised modifications;
- use of secure environments (e.g. containers);
- implementation of a zero-trust model for access to AI services;
- securing AI systems against injection attacks, rate limiting to prevent denial-of-service attacks.

Data quality. The term "data quality" typically encompasses several aspects, such as completeness, accuracy, validity, consistency, appropriateness or representativeness, and integrity.

While ensuring data integrity is one of DORA's protection objectives, the regulation does not contain any provisions for other aspects of data quality. Nevertheless, high data quality, especially for training data, is a key requirement for deploying artificial intelligence, as the accuracy, reliability and performance of AI systems depend on it. Data quality requirements are typical components of governance structures for the use of AI. See the case study for specific details on AI assistants and LLMs.

3. Reporting major ICT-related incidents

Reporting major ICT-related incidents. Financial entities are obligated to promptly report major ICT-related incidents to the competent authorities (Article 19 of DORA). This reporting obligation may also include incidents in AI systems. Rapid response mechanisms are necessary because, for example, **the manipulation of AI systems can cause significant operational harm in a short period of time**.

Entities must develop a policy for the ICT-related incident management process. Ideally, this policy should also address AI systems.

Article 17 of DORA

ICT Incidents

Financial entities shall define, establish and implement an ICT-related incident management process to detect, manage and notify ICT-related incidents.

Likewise, technical, organisational and operational mechanisms to support the ICT-related incident management process should be implemented and operated (Article 22 of the RTS RMF).

Incidents that occur due to or in connection with ICT systems, such as AI systems, that compromise the security of network and information systems and breach IT protection objectives for data or negatively impact services provided must be recorded as ICT-

related incidents (Article 17 of DORA). In this context, entities are encouraged to identify incidents related to AI systems accordingly.

When using AI systems in the cloud, **entities are encouraged to make arrangements for reporting ICT incidents that occur in AI systems**. Entities should also make sufficient qualified internal resources available for assessment and response.

Best practices for incident management include:

- identifying **AI-specific threats** (e.g. manipulation of training data);
- detecting ICT incidents arising from AI systems so that immediate action can be taken in response to e.g. model errors, data loss or performance problems;
- impact analysis (e.g. data loss) of ICT incidents arising from AI systems and classification of severity levels;
- integration of such incidents into the general incident response policy.

After such incidents, a detailed root cause analysis is recommended to identify and remedy systematic weaknesses in AI models and processes. These findings can be used in continuous improvement measures to sustainably prevent repeated ICT incidents in AI systems.

VI. Conclusions and outlook

Using AI systems offers significant potential for financial entities, not least due to more efficient internal processes and more granular risk management. However, increased use of AI also entails greater risks.

It is therefore necessary for financial entities to first define appropriate governance and organisational structures to mitigate ICT risks arising from AI systems. DORA specifies sufficient requirements to establish an effective ICT risk management framework for such systems.

Developing and testing AI systems poses particular challenges for entities. This is due to the often-high complexity of the mathematical models, the amount of data to be processed, and the integration of software from ICT third-party service providers. AI systems developed internally and externally must be analysed and tested according to the same standards.

Appropriate processes must be defined for AI system operation. These should identify risks and ICT incidents throughout the entire AI system lifecycle and initiate countermeasures. Because AI systems often run in cloud environments, the requirements for using ICT third-party service providers must be interpreted accordingly.

As financial entities use AI systems to process confidential data, typically customer data, the systems must be secured against unauthorised access and data leaks. Cyber- and data security are very important, which may require significant efforts on the part of the entities to classify data into confidentiality levels. Suitable reporting processes must be established for major ICT-related incidents.

These requirements are particularly relevant for AI assistants, which are often included in standard software. Implementing AI assistance systems at a financial services entity requires a holistic security strategy that encompasses technical, organisational and regulatory measures.

Case study – operating an LLM-based AI assistant

A financial services entity plans to implement an LLM-based AI assistant to support employees in creating texts, emails and presentations. As the entity works with sensitive financial and customer data, strict security and compliance requirements must be met.

This case study describes typical risks involved in implementing this kind of AI application. Three infrastructure variants are examined: the on-premise solution and two variants with cloud operation – first an AI application in the entity's own tenant, and second an AI application outside the entity's own tenant. Figure 2 illustrates the concepts behind these two variants.

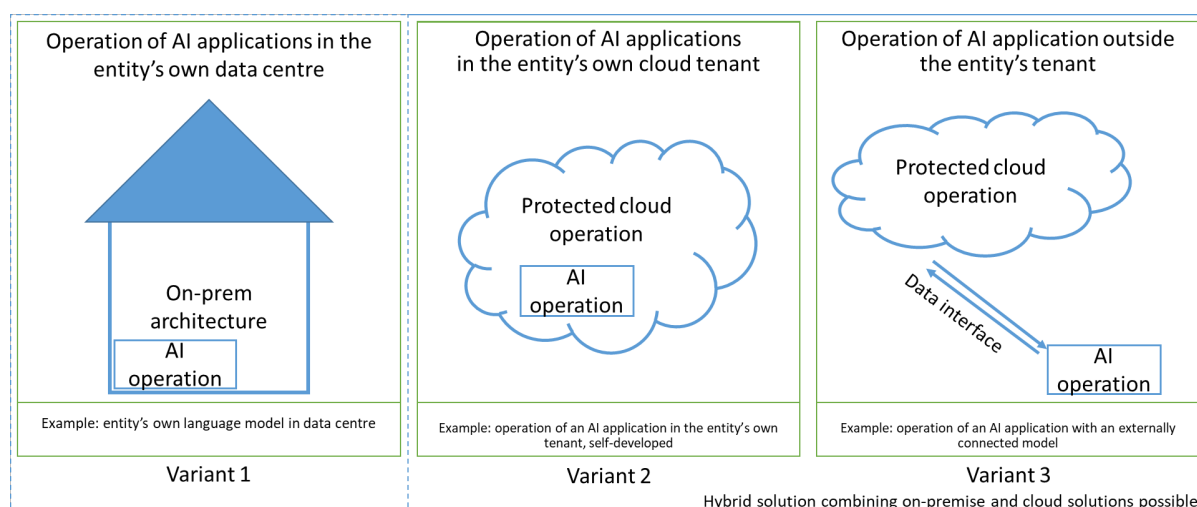


Figure 2: Archetypal infrastructure options

The case study presents an illustrative discussion of selected ICT risks that can be observed when AI assistants are used. It does not express any supervisory expectations. All measures presented in the case study are illustrative. By contrast, financial entities must implement the measures that are most appropriate for their specific risk situation.

The specific ICT assets and infrastructure used at financial entities may also represent a combination of elements from the three variants. The following discussion of risks should then be modified accordingly.

Independently of this, there are risks that are significant in every infrastructure variant. Key examples along the AI lifecycle are as follows:

1. Data acquisition and processing: A significant risk is that the AI application will process data that has not been approved for use in the application. This is why it is essential for the data to

be comprehensively classified by confidentiality level. Selected measures can be categorised in greater detail as follows.

Data classification and access control:

- automated detection and classification of confidential data wherever possible;
- in-depth training on how to use the AI application;
- implementing a zero-trust policy, under which the AI application can only retrieve authorised data, as well as introduction of a role-based model for data access for AI application users.

Data minimisation and masking:

- using differential privacy wherever possible to protect personal data from possible inferences in the context of multiple queries (maximising the accuracy of responses to database queries while minimising the likelihood that the data sets used to answer the queries can be identified);
- tokenisation of sensitive data before processing by the AI assistant.

Identification and avoidance of data bias:

- data validation and cleansing prior to use, including automatic validation or manual sampling;
- training users to select and process data.

2. Model development and training: When training or fine-tuning LLMs, there is a risk that manipulated data will be used, which can lead to unexpected or altered model behaviour. The following measures can be considered here:

- ensuring that the AI assistant is only trained/fine-tuned with verified and validated entity data to avoid “data poisoning”. It may also be helpful to establish a data governance team to control which data is released for AI processing;
- ensuring that the data provided to the LLM as a knowledge base in Retrieval Augmented Generation (known as “context” or “grounding”) is also verified and validated to avoid knowledge poisoning;
- version control systems for models to enable rollback in the event of e.g. malfunction or faulty training;
- for each type of generative AI application, entities are encouraged to develop and use their own testing procedures that reflect the specific requirements of the use case.

Similar to data poisoning, there is also something known as “model poisoning”. This risk occurs particularly with open source models or models obtained from shared repositories. In this case, attackers attempt to modify the behaviour of a trained model or even the structure of the model itself. Best practice measures for risk mitigation include:

- reviewing the source code of publicly available models for backdoors and malicious code;
- ensuring the integrity of repositories and model providers.

In addition, even when a pre-trained model is used, attackers can attempt to implement backdoor attacks or adversarial manipulations. Examples of potential countermeasures include:

- implementing an auditing framework that logs all queries to the AI assistant and makes them verifiable. Explainable AI techniques for explaining the AI assistant's outputs are useful here;
- deploying anomaly-detecting security mechanisms to identify unusual model responses or suspicious queries;
- conducting regular penetration tests for the AI assistant environment to identify vulnerabilities at an early stage, as well as a red teaming approach in which security experts attempt to manipulate the model and discover vulnerabilities.

3. Model deployment and integration: ICT risks also arise in this phase of the AI lifecycle. In particular, if the AI assistant is not implemented securely, attackers can gain unauthorised access to internal systems or exfiltrate model information. The following measures have proven to be effective here.

Deployment strategy:

- deploying the AI assistant in an isolated cloud environment to prevent direct internet access;
- using containerisation to isolate the AI environment from other ICT systems.

Access control and authentication:

- implementing multi-factor authentication (MFA) for AI assistant users;
- using conditional access policies so that only authorised users with the entity's own devices can use the AI assistant;
- critical examination of interfaces and access rules to other systems within the entity, incorporating the human-in-the-loop principle (e.g. approval by the data owner).

API security:

- All API queries between the entity's systems and the AI assistant are conducted through encrypted interfaces.
- Rate limiting and DDoS protection through cloud security mechanisms help to prevent overload attacks.

4. Operation and use: Integrating LLMs into business processes entails a wide range of risks. Besides challenges that are not directly related to ICT (such as "hallucinations", which is when the model makes convincing statements that appear to be correct but are actually wrong), various ICT risks are relevant. These include the following major topics:

First, there is the extraction/disclosure of sensitive business information from fine-tuned, publicly accessible LLMs. In this case, selected confidential information from the training data set can be reproduced using appropriate prompts. There is a risk here that malicious prompts (known as "prompt injection") could force the LLM to behave in an unintended way, e.g. by

linking to websites that contain hidden instructions for the LLM. The following measures, among others, can be taken to counter these risks:

- using explainability tools that enable users to understand why the AI is giving a particular answer;
- providing AI safety training for employees to minimise misinterpretation and careless use;
- investigating which prompts lead to what effects and defining appropriate restrictions.

Second, a compromised or malfunctioning AI assistant may disclose confidential information to users who do not actually have access to this data. In this context, processes for monitoring the AI application and detecting anomalies can be used, e.g.

- implementing situation-specific monitoring of AI interactions;
- identifying abnormal activities within the AI assistance environment.

Third, API access to LLMs can give attackers an opportunity to access systems connected to the LLM and thereby extract confidential information. In addition to assigning appropriate access rights, financial entities should also consider isolating LLMs. Other potential measures include:

- mitigating this risk by restricting the use of LLM for AI systems that support critical or important functions;
- introducing a human review requirement (human-in-the-loop) for security-critical AI responses/recommendations.

5. Maintenance, updates and incident response: In particular when using open source LLMs, entities must consider that outdated or incorrectly configured software versions can lead to security vulnerabilities. Selected measures to counter this risk include the following.

Regular security updates:

- automatic updates for the AI assistant controlled automatically using a suitable tool, as well as using patch management tools to quickly close security gaps;
- introducing a security incident response plan (SIRP) for AI assistant-specific security incidents;
- simulating cyberattacks to test the entity's response times.

Governance requirements:

- regular external audits to ensure that the AI assistant continues to comply with the entity's policies;
- centralised recording of governance aspects in the form of a compliance dashboard that provides transparency about usage (e.g. model version, risk assessments, responsibilities).
- In addition to generally applicable requirements, it may also be advisable to consider technological features for AI systems, such as on-premises and/or cloud-based systems.

6. End-of-life management: The uncontrolled continued use or unsafe retirement of AI assistants can lead to the misuse of historical data and models or their unintentional public disclosure (leaks). As with all ICT assets, financial entities must therefore also plan for the retirement of LLMs and associated data sources. Potential best practice measures for risk mitigation include the following.

Secure retirement of AI assistants:

- deleting all data used and historical AI interactions in accordance with GDPR guidelines;
- using cryptographic wiping to securely remove all stored data of the entity;
- blocking the AI assistant for expired user accounts or former employees;

The specific features of the selected infrastructure models will now be examined in the following. Investment costs and operating costs are not considered here. Such costs will arise to a greater extent in each variant, as either the establishment and operation of a separate infrastructure will be necessary, or the secure configuration of the model may lead to increased cloud spending.

Variant 1: On-premise solution

In this variant, the financial entity has its own storage and processing capacities and operates AI software developed (partially or completely) internally on its own hardware. This is the case when the entity implements, maintains, trains, and operates an LLM itself. This means that all data flows remain within the entity's own infrastructure. The financial entity has full control over the ICT assets of the AI application, but bears all the risks associated with the development, operation and, above all, maintenance of the hardware and software: both the strategic risk of the business model and the operational risk of the ICT system are significant here.

The specific risks of this approach are reflected in the AI lifecycle, particularly in model development and operation. In the first instance, implementing and maintaining open source models in particular demands sufficient knowledge and skills, meaning that the availability of suitable employees is a strategic risk.

There is a risk of vulnerability to cyberattacks, particularly when an entity operates models it has implemented itself or open source models. If the AI assistant is not implemented securely and is not continuously updated, attackers can gain unauthorised access to internal systems or exfiltrate model information. A suitable protective measure is closely controlled access management, as the effects of uncontrolled access are much greater when an entity uses AI than without it.

Additionally, capacity management is increasingly important in this infrastructure variant. Unlike cloud variants, the AI application cannot be scaled at will without expanding the hardware. The infrastructure must therefore be tailored to the expected computing power, regularly checked and adapted if necessary.

Variant 2: Cloud with AI application in the entity's own tenant

In this case, the financial entity has its own tenant in a cloud environment. An AI assistant (such as an internally implemented open source model) is operated inside this tenant. This means that although data flows happen in the cloud, they are still exclusively inside the entity's tenant.

The main risk in this variant is strategic in nature, as there is a high degree of dependency on the model operator if no open source implementation is used. One mitigating measure could be to use several models from different providers, although this would lead to increased operating and maintenance costs. In addition, employees must have the appropriate skills and knowledge, especially if they are using open source software.

There are also challenges with regard to capacity management, as it is not always possible to scale the AI application inside the tenant. One possible countermeasure is early capacity planning.

Variant 3: Cloud with AI application outside the entity's own tenant

In this variant, the financial entity has a tenant in a cloud. However, the AI application is located outside this tenant, meaning that data flows extend beyond the boundaries of the tenant. This occurs typically when a large language model from the cloud provider is accessed via an API or called up as an AI assistant from standard software (possibly without the user's knowledge).

The main risk in this scenario is that data leaves the tenant and flows to the model provider. This should be counteracted by contractual and technical measures. Selected technical measures for this include:

- restricting functionality (including limiting uploads) for certain user groups;
- operating a filter that checks whether input data is confidential (Governance Shield);
- presetting the conditions for AI application in advance of each use.

Another potential mitigating measure is to assign the AI application a lower data clearance level, meaning e.g. that it can only process less sensitive data. It should be noted that users cannot exceed these restrictions of their own accord.

Technical control of IT operations, information security, etc. should be carried out in line with the Cloud supervisory statement.

Publishing information

Published by

Federal Financial Supervisory Authority (BaFin)

Directorate-General for Cyber Risks and Technology in the Financial Sector

Graurheindorfer Strasse 108, 53117 Bonn

Marie-Curie-Strasse 24 – 28, 60439 Frankfurt am Main

www.bafin.de

Index of Abbreviations

A

API application programming interface

B

BaFin Federal Financial Supervisory Authority

BAIT Supervisory Requirements for IT in Financial Institutions

C

CRR Capital Requirements Regulation

D

DAST dynamic application security testing

DLP data loss prevention

DOR digital operational resilience

DORA Digital Operational Resilience Act, Regulation (EU) 2022/2554 of the European Parliament and of the Council of 14 December 2022 on digital operational resilience for the financial sector

DDoS distributed denial of service

DoS denial of service

E

EU European Union

G

GPU graphics processing unit

GenAI generative AI

I

IDS intrusion detection system

EUC end-user computing

ICT information and communication technology

IPS intrusion prevention system

K

KAIT	Supervisory Requirements for IT in German Asset Managers
AI	artificial intelligence
AI Act	Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence
L	
LLM	Large Language Model
M	
MaRisk	Minimum Requirements for Risk Management, BaFin Circular
MFA	multi-factor authentication
ML	machine learning
O	
OECD	Organisation for Economic Co-operation and Development
R	
RBAC	role-based access control
RTS	Regulatory Technical Standard
RTS RMF	Delegated Regulation (EU) 2024/1774 of 13 March 2024 supplementing Regulation (EU) 2022/2554 of the European Parliament and of the Council with regard to regulatory technical standards specifying ICT risk management tools, methods, processes, and policies and the simplified ICT risk management framework
S	
SAST	static application security testing
SIRP	security incident response plan
SLA	service level agreement
V	
VAIT	Supervisory Requirements for IT in Insurance Undertakings
VPN	virtual private network
X	
xAIT	Collective term for BAIT, KAIT, VAIT and ZAIT
XAI	explainable AI
Z	

